Statement of Qualifications

Uriah Raffer | JC-521525 | Information Technology Specialist I

1. Describe your experience assessing cybersecurity control maturity using frameworks such as NIST CSF 2.0, HIPAA Security Rule requirements, or Zero Trust Architecture principles. Include specific examples of how you evaluated controls, validated documentation, or conducted stakeholder interviews.

My hands-on control-assessment work comes from a Windows 11 STIG compliance project during my cybersecurity internship. Using Tenable Nessus, one of the platforms the internship runs on, I ran a Defense Information Systems Agency (DISA) Microsoft Windows 11 Security Technical Implementation Guide (STIG) audit against a Windows 11 virtual machine, which checks the system against a published baseline of required security controls. The audit flagged a set of failing controls and I worked through ten of them. For each one I read what the control required, compared it against the machine's actual configuration, applied the fix with PowerShell, and re-scanned to confirm it passed. The specific controls make the work concrete. I disabled WDigest authentication so credentials weren't cached in memory, enforced a minimum password length of fourteen characters, and restricted Kerberos to strong encryption by removing the weak DES and RC4 ciphers.

That is control evaluation against the DISA STIG framework, and it's the same discipline this role applies with other standards. I have working knowledge of the National Institute of Standards and Technology (NIST) Cybersecurity Framework from my B.S. in Network Engineering and Security and my CompTIA Security+ certification. I understand how the framework organizes controls into functions such as Identify, Protect, and Detect, and how a maturity assessment rates how fully each control is implemented rather than treating it as simply present or absent. Reading a control requirement, weighing the evidence, and judging where a system stands against it is work I'm comfortable doing.

2. Explain your experience supporting audits or compliance activities, including preparing evidence, documenting findings, and tracking remediation. Describe your experience presenting cybersecurity or compliance findings to stakeholders and interpreting those findings into clear, actionable recommendations.

I supported a full remediation cycle in a vulnerability management project during the same internship. I built a Windows Server with a range of known weaknesses, ran an authenticated Tenable scan to surface them, and the scan returned findings across critical, high, medium, and low severity. I documented each finding, then set a remediation order based on impact and ease of fixing rather than working at random. I cleared the outdated third-party software behind the critical findings first, then moved through insecure protocol and authentication settings such as Server Message Block (SMB) signing and Remote Desktop Network Level Authentication, down to the lower-severity items. After each fix I re-scanned to confirm the finding was closed and kept that result as evidence.

I also validate findings instead of taking the scanner at its word. One scan intermittently reported a SQLite vulnerability that showed up in some runs and not others, so I investigated it directly. I searched the system for SQLite binaries and library files with

PowerShell, found none installed, and documented it as a false positive that didn't need remediation. Turning a raw scan into a clear, ordered, verified record is the part of this work that maps to compliance support. A finding list on its own is just output. The value is in deciding what matters, fixing it in the right order, and leaving documentation a reviewer can follow and trust.

3. Describe your experience analyzing technical or security data to develop baselines and monitor progress in cybersecurity posture. Include examples where you transformed assessment results into actionable outputs such as scorecards, dashboards, automation scripts, or comparative reports. Explain your role, the tools or methods used, and how your work supported decision making or improved security outcomes.

My strongest data-analysis work is in security log analysis and automation. During the internship, investigating activity on a public-facing host, I wrote Kusto Query Language (KQL) queries against the sign-in logs in a security information and event management (SIEM) platform, projected the fields I needed, and filtered down to the failed authentications. That surfaced close to one hundred failed Secure Shell (SSH) login attempts, a clear brute-force pattern against password authentication that was buried in a much larger volume of routine log entries. Finding it meant querying and filtering the data deliberately, not just reading a dashboard. I then drive remediation through scripting, using PowerShell on Windows and Bash on Linux so a fix is applied as a repeatable, documented action rather than by hand on each machine.

I also turn scan data into a measure of progress over time. In the remediation project I re-scanned after every fix and tracked the results across six scans, which let me chart the finding count falling from thirty to three, roughly a ninety percent reduction, with the critical findings eliminated by the second scan and held there. That chart is a simple comparative report. It shows whether security posture is actually improving instead of giving a single snapshot. In the STIG project I used the same re-scan-to-confirm loop to prove each control moved from failing to passing against the baseline. The method carries across tools. I collect the data, find what matters in it, act on it through automation, and measure the result against where I started.